11.2.3 Acquiring OAuth tokens

The core of OAuth is the grant, the process through which a client application obtains an access token. There are several different types of grants. Each follows a slightly different path, depending on whether a human is involved, the type of client making the request, and the required security level. The primary method for obtaining a token is the *Authorization Code Grant*, where a person logs in and explicitly approves the scopes of access, and the client then exchanges that approval for a token. Other grants, like *Client Credentials*, allow server-to-server applications to acquire tokens directly without user interaction. There are also other types, such as the *Implicit Grant* and *Resource Owner Password Credentials Grant*, which are used for specific cases but are less common.

AUTHORIZATION CODE GRANT

The *Authorization Code Grant* is the most common method for a person to authorize an application to access their data. The flow is designed to be secure: the user never shares their password with the client application, and tokens are exchanged directly between the client and the authorization server over a secure channel.

At ACME, Kate wanted to use BI Explorer, a reporting tool, to create dashboards using data from the Customer Collaboration platform. BI Explorer needed to access document metadata and workspace information, but it should do so only with Kate’s permission and within the boundaries of her account. The Authorization Code Grant offered the right balance of usability and security. Figure 11.5 shows the flow for the code grant.